CS 205 Final Term file Made BY M. Qasim Ali 03337435091

U tube channel QASIM KHAN WORLD

For any help contact 03337435091

MCQ No 1: Creating awareness relating to policy and ISMS fall under ---------- Clause.

A. Support
B. Operation
C. Performance evaluation
D. Leadership

MCQ No2: OWASP software assurance maturity model (SAMM) undertakes software security testing and validation during ……

A. Governance and deployment
B. Governance and verification
C. Verification deployment
D. Construction and Governance

MCQ No 3: -------- Technique / Solution can be used to analyze and block inbound email attachments with malicious behavior.

A. Enterprise antivirus
B. Sandboxing
C. Siem solution
D. Fim solution

MCQ No 4: Assigning resources, assignment rules and communicating roles fall under--------- clause.

A. Support
B. Leadership
C. Performance evaluation
D. Operation

MCQ No 5: The objective of COBIT is to help organization ----------.

A. Create optical values from it by balancing benefits with risk
B. Implement a strong governance of it
C. Manage it effectively while ensuring business continuity
D. Create a single page it dashboard

MCQ No 6: In security transformation model ownership of validation of controls lies with

A. IT operation team
B. Business team
C. Info security or consultant
D. IT help desk team

MCQ No 7: where should source code be kept as best practice?

A. Access control system
B. Change control system
C. Version control system
D. Source control system

MCQ No 8: As per ISO27001 Operating procedure should be

A. Confidential
B. Verbally communicated
C. Decided on adhoc basis
D. Documented and available to who need them

MCQ No 9: It seems to conducting a successful security transformation project is more challenging in a?

A. Large size organization
B. Medium size organization
C. Small sized organization (Not sure may be C or May be D)
D. Environment where multiple sites are present

MCQ No 10: Stage 2 of security transformation refers to

A. Security Governance
B. Security engineering
C. Security hardening
D. Vulnerability management

MCQ No 11: ---------should be used to ensure that critical system files have not been altered.

A. CIS cat pro
B. Qualys vulnerability scanner
C. Security information and event monitoring tools
D. File integrity monitoring tool

MCQ No 12: An authentic information head always ----------

A. Take credit of every thing
B. Never admits mistakes and failure
C. Give credit where it is due
D. Very strict and disciplined

MCQ No 13: Network performance degradation can be faced in ---------- step of VM cycle.

A. Preparing the scanner
B. Analyzing the asset
C. Running the scanner
D. Applying the patches

MCQ No 14: ---------- category vulnerabilities have the highest severity in Qualys scan.

A. Level 2
B. Level 3
C. Level 4
D. Level 5

MCQ No15: ISO31000 guidelines are centered on----------?

A. Organization context
B. Leadership and commitment
C. Planning
D. operation

MCQ No 16: ----------plays an instrumental role in success of security transformation program.

A. IT team lead by CIO
B. Business team
C. Internal team
D. Highest management

MCQ No17: --------should be deployed to limit and control that which devices can be connected to the network?

A. 802.1x
B. 802.11g
C. 802.11b
D. 802.11n

MCQ No 18: all network traffic to or from internet must pass through ---------- to filter unauthenticated connections.

A. Application layering proxy
B. Session layer filtering proxy
C. Network layer filtering proxy
D. System layer filtering proxy

MCQ No 19: in which phase of Security assessment, assessment method based on report format are decided

A. Report finding
B. Build plan, scope and objectives
C. Assign role
D. Conduct assessment

MCQ No 20: Automated tool should be used to verify and compare the network device configuration with ----------

A. Approved security configuration
B. Recommended security configuration by vendor
C. Latest security configuration released by vendor
D. Default security configuration released by vendor

MCQ No 21: Under security transformation model which team is responsible for validation of control?

A. Business team
B. Info security team or consultant
C. IT operation team
D. IT help desk team

MCQ No 22: The computer security resources center (CSRC) website guides user to ------- resources?

A. CIS resources on computer , cyber, information security and privacy
B. SANS resources on computer, cyber, information security and privacy
C. NITS resources on computer , cyber, information security and privacy
D. PCI resources on computer , cyber, information security and privacy

MCQ No 23: Complex password should be enforced to survive ----------?

A. Dictionary attack
B. Injection attack

C. DOS attack
D. Phishing attack

MCQ No 24: ---------- activities are carried out in phase 1 (Pilot phase) of information security transformation program?

A. Perform hardening of Key IT asset in Test environment
B. Understand origination and its security issues
C. Develop ISMC
D. Identify assets for various phases

MCQ No 25: Candidness quality of information security head means that he-----?

A. Promote performance and merit
B. Encourage-solo flight of team member
C. Honesty and straight talk
D. Adjust players in right position

MCQ No 26: ----------protocol used for assigning address dynamically?

A. DCP
B. HTTP
C. DHCP
D. IP

MCQ No 27: -------Team has primary ownership of vulnerability management process?

A. Information security team.
B. IT operation team
C. Business team
D. Risk and compliance team

MCQ No 28: --------Rules are mentioned relate to C++ security hardening?

A. Seven
B. Eight
C. Nine
D. Ten

MCQ No 29: ------ is goal f performing audit

A. Testing Security that is Assumed to be secure
B. Technical assessment design to achieve specific goals
C. To fix as many things are possible and efficiently as possible
D. Focuses on how on existing configuration compare to standard

MCQ No 30. Under security transformation model which team is responsible for implementing controls?

A. It operation team
B. Security consultant
C. Risk compliance team
D. Business team

MCQ No 31: In ----------assessment tester has full access to all internal information about the target?

A. White box assessment
B. Grey box assessment
C. Black box assessment
D. Risk assessment

MCQ No 32: -------- assessment is designed to determine whether an attacker can achieve specific goals when facing your current security posture?

A. Threat assessment
B. Bug bounty hunting
C. Penetration testing
D. Red team exercise

MCQ No 33:--------- are the key benefits of security transformation project implementation to an organization?

A. IT team get experience and aware of security
B. Prevention of attack
C. IT team gets incentives
D. Management becomes aware of IT team capability

MCQ No 34: --------- action is recommended for organization having very good security posture and has a score higher than 85%?

A. Go for risk assessment
B. Third party security review
C. Go for ISO27001 certification
D. Information security transformation program

MCQ No 35: Version of security related updates should be applied on network devices?

A. Latest
B. Default

C. Latest and stable
D. Oldest

MCQ No 36: Most of the problem associated with week security posture is due to --------?

A. Lack of awareness
B. Lack of funds
C. Lack of experience
D. Lack of commitment

MCQ No 37: The information security policy need to be ----------?

A. Review once in three year
B. Update once in five year
C. Locked in drawer and kept confidential
D. Regularly reviewed and approved for the changes

MCQ No 38: In case of financial sector ---------- regulations need to be reviewed and understood to raise management support for security transformation?

A. SBP
B. PTA
C. PEMRA
D. PEPRA

MCQ No 39: Inventory of authorized and unauthorized software control require making a list of ------?

A. Authorized access and version
B. Authorized operating system and version
C. Authorized software and version
D. Unauthorized software and version

MCQ No 40: Which principle should be used when setting up a user in data base?

A. Principle of normal user
B. Principle of administrative user
C. Principle of least privilege
D. Principle of highest privilege

Q. 41. …… which team has primary owner ship in vulnerability management?

ANS: **Information security team**

42. Steps involved in vulnerability management?

Ans: Identify, classify, remediate, and mitigate the vulnerability

43: For creating scanning policies, qualys built in policies library include.

Answer: CIS and DISA policies

44. What is the first step in automated mechanism of security hardening and validation??

Ans: Scan an IT asset using Qualys nessus compliance scan

45. There are------ benefits of version control.

ANS: SEVEN

46: ISO 31000 guidelines are centered on?

Ans: Leadership and commitment.

48- Chose the correct statement:

- Allow all IP address

- Deny all IP address

- Deny communication with known malicious IP address

- Allow communication with unused IP address

49: In small sized security organization in Pakistan, It is likely the number of security stall will?

Ans: 1-5 or 2-4

50: In Medium sized security organization in Pakistan, It is likely the number of security stall will?

Ans: 10-15

51: In Large sized security organization in Pakistan, It is likely the number of security stall will?

Ans: 30

52: What was the old name ISO27002:2013?

Ans: ISO17799

53: In PHP Guidelines “display error" shows

A. On

B. off

C. True

D. False

54: Android managers set as

A. True

B. false

C. Enable

D. Disable

55. By default Android management set as (is ka ans hai NoT ENABLE But option main not enable ni hai ap jo laga lo)

A. True

B. False

C. Enable

D. Disable

56. What is the Fifth layer of CSMM?

Ans: Monitored

57. What is the Sixth layer of CSMM?

Ans: Secured

58: The number of ports is configurable, but the default scan

Ans: approximately 1900 TCP ports and 180 UDP ports.

59: Guidelines should be

A. Open to interpretation.

B. Strictly enforce

C. Pasted on the notice board for easy visibility

60: Which of the following changes are easiest to prioritize and implement?

A. Emergency change

B. Standard change

C. Unknown change

D. Normal change

61: In which format results of penetration testing should be documented?

A. XML format

B. Excel format

C. Machine readable standard

D. PDF format

62: When a Flaws in infrastructure related to service need to be addressed immediately, this would be a?

A. Predictable change

B. Emergency change

C. Normal change

D. Standard change

63: The total numbers of discretionary controls in appendix a5 through a18 are:

A. 114

B. 121

C. 20

D. 10

64: One of the challenges of iso27001:2013 (isms) is that:

A. Is short and concise

B. It is generic and not specific

C. It has too few mandatory requirements

D. The annexure does not always apply to every type of organization

65: With how many time sources the clocks of all relevant information processing systems should be synchronized to record events and generate evidence

A. Single time source

B. At least four time sources

C. At least two time sources

D. At least three time sources

66: The ciso should be able to complete his or her own Technical knowledge by?

A. Seeking extra buget from board

B. Relying on it department to implement security controls

C. Building a god team

D. Outsourcing work to a third parties

67: While Implementing 4-layer security transformation model?

A. There should be absolutely no policy inline

B. Policies and procedure are not all required

C. It is suggested to have a high level and minimal policy in place

68: which of the following come at the center of Risk management process?

A. Context of organization

B. Planning and operation

C. Leadership and comment

D. Risk Assessment and risk treatment

69: If multi-factor authentication is not supported then user accounts shall be required to?

A. Use short passwords which are easy to remember

B. Use same password on all the systems

C. Use passwords longer than 14 characters

D. Use default passwords

70: PHP seeing guidelines cover which type of attack?

A. Denial of service (DOS)
B. Brute force attack
C. Injection attack (according to chat GPT)
D. Dictionary attack

71: CIS critical control required to ensure that _____ is taken?

A. Automatic backup
B. Manual
C. Twice a year
D. Once a year

72: _____Should be documented in configuration management system about network device?

A. Configuration rules
B. Vendor name
C. Date of purchase
D. End of life time

73: The first tool used by an attacker once he has identified the IP address to be targeted.

A. System port scanning
B. Identification of targets
C. System exploitation

74: _____ type of Scripting Languages should be used in Web Browsers and Email Clients & web browser??

A. Authorized scripting languages
B. Client side scripting languages

75: Free Nessus scanner offer trial version _____ days?

Ans : 7 days

CS 205 past papers files and Important Questions for Final exams Fall 2024

Made by Muhammad Qasim Ali

For any query contact 03337435091

U tube Channel QASIM KHAN WORLD. Kindly subscribe

Q No 01: very important. Security Breach in HOME Department 2014

How much card played: • 56 million payment cards compromised

Which kind of vulnerability exploited: Then they exploited a zero-day vulnerability in Windows Or Exploitable vulnerabilities were found in anthem network

How much mail used: The malware was also able to capture 53 million email addresses.

• 56 million payment cards compromised •

Early September 2014

– This malware was able to grab 56 million credit and debit cards. The malware was also able to capture 53 million email addresses (winter, 2014).

Q no 02: Topic no 125: Security Breach Case Study 2: Anthem

How much People effected: Affected 78.8 million individuals

How Much Account used or utilized: The attacker utilized at least 50 accounts

How much system compromised: compromised at least 90 systems

Which way used: A phishing email containing malicious content (Also MCQZ)

Q No 03: What is vulnerability?

– Vulnerability is a cyber-security term that refers to a flaw in a system that can leave it open to attack. Vulnerability may also refer to any type of weakness in a computer system itself, in a set of procedures or in anything that leaves information security exposed to a threat.

What is vulnerability management? VM – Vulnerability management is the "cyclical practice of identifying, classifying, remediating, and mitigating vulnerabilities" •

What is vulnerability assessment (VA)? – A process that defines, identifies, and classifies the security holes (vulnerabilities) in a computer, network, or communications infrastructure

Q No 04: Topic no 118: What Are The Steps In VM Lifecycle?

VM Steps:

1. Analyze assets
2. Prepare scanner
3. Run vulnerability scan
4. Assess results
5. Patch systems
6. Verify (re-scan)

Q No 05: What are some of the common vulnerability scanners?

- Open VAS
- Nessus
- Qualys
- Rapid7

Free tool offered. By Qualys (IMP)

Browser check

SSL

Qualys Free Scan

1. Vulnerability – 2. OWASP – 3. Patch Tuesday – 4. SCAP

Q No 06: Topic no 127: Who Conducts Vulnerability Management?

SN	ACTIVITY	TEAM	SUPPORTED BY
1	ANALYZE ASSETS	INFOSEC	IT OPS TEAM
2	PREPARE SCANNER	INFOSEC	-
3	RUN VULNERABILITY SCAN	INFOSEC	-
4	ASSESS RESULTS	INFOSEC	IT OPS TEAM
5	TEST & PATCH SYSTEMS	IT OPS TEAM	INFOSEC
6	VERIFY (RE-SCAN)	INFOSEC	IT OPS TEAM
7	REPORT FINDINGS	INFOSEC	IT STEERING COMMITTEE

Q No07: Role of Infosec team:

– Takes the primary ownership of the vulnerability management process

– Runs scanning after coordinating with the relevant IT Ops team

– Shares scanning reports with IT teams and management

– Tracks remediation timelines

– Understands criticality issues and helps to prioritize

Q No 08: Role of IT Ops team:

– Owner of the IT asset

– Receives the vulnerability scan report from Infosec team

– Studies the vulnerability – Understands criticality, impact, & dependencies

– Helps Infosec team develop a project plan (if required) and timelines for the patching

– Tests the patches in test environment – Takes backups, develops roll-back plan

– Takes downtime and takes ownership of the change management process

– Implements the patches

Q No 09: Topic no 129: Qualys Features

– Cloud-based service
– On-premise device
– Complete suite
– Scalable and immediate deployment
– Asset discovery; find and organize hosts
– Prioritize & manage remediation tickets
– Continuous monitoring service
– Policy compliance scanning

Q No 10: Topic no 136: How Do VM Scanners Work?

• Lets take a look at Qualys scanning technique:
• Qualys Guard scanning methodology mainly focuses on the different steps that an attacker might follow

in order to perform an attack.
• It tries to use exactly the same discovery and information gathering techniques that will be used by an
attacker.

– **Checking if the remote host is alive**

– The first step is to check if the host to be scanned is up and running in order to avoid wasting time on scanning a dead or unreachable host

– **Firewall detection**

– The second test is to check if the host is behind any firewalling/filtering device. This test enables the scanner to gather more information about the network Infrastructure and will help during the scan of TCP and UDP ports.

– **TCP / UDP Port scanning**

– The third step is to detect all open TCP and UDP ports to determine which services Are running on this host. The number of ports is configurable, but the default scans Is approximately **1900 TCP ports and 180 UDP ports**.

Q No 11: Topic no 141: VM Challenges & Pitfalls

Challenges:
– Internal expertise on VM tool
– Not enough support from IT teams
– Vulnerability patching causing application failure
– Management support

Q No 12: Topic No 145: WHAT IS SECURITY ENGINEERING?

• Security Engineering is the third layer of the Security Transformation Model

• Consists of more in-depth and complicated security activities which take more time and effort

• Many times related to security architecture

Q No 13: Types of activities for security engineering:

• FW granular access lists

• Building an effective DMZ architecture

• Segregating the network with VLANs

• Adding a security tool such as SIEM, FW, DLP, NAC, etc

• App-DB encryption

Q no 14: Topic No 146: WHAT IS THE OBJECTIVE OF SECURITY ENGINEERING? (MOSTLY)

• Security architecture as per best-practices

• The right security devices in the right places

(Examples:

• FW first and then IPS

• Edge FW, data center FW

• Malware protection at the network edge)

• Effective security configuration of security devices (features)

• Optimum operation of security devices

• Aggregate controls

Q No 15: Steps in Security engineering: (Repeated)

– Assess risk profile

– Research security solutions

– Design security architecture

– Implement security controls & solutions

– Test and validate security posture

Q No 16: Security transformation project:

• Security transformation project time line:

– Project initiation: 2 Mths

– Layer 1: security hardening of IT assets (6 Mths) –

Layer 2: VM (1 Mth)

– Layer 3: security engineering (1 Mth)

– Layer 4: Governance & ISO cert.(3 Mths)

Q No 17: Most Important: (read and keep in mind about steps Basic Foundational and organizational)



- **Inventory of Authorized and Unauthorized Devices**

Deploy an automated asset inventory discovery tool and use it to build a preliminary inventory of systems connected to an organization's public and private network(s). Both active tools that scan through IPv4 or IPv6 network address ranges and passive tools that identify hosts based on analyzing their employed. traffic should be

- **Secure Configurations for Hardware and Software**

Establish standard secure configurations of your operating systems and software applications. Standardized images should represent hardened versions of the underlying operating system and the applications installed on the system.

- **Topic No 159 & 160: CSC7-I: EMAIL AND WEB BROWSER PROTECTIONS :**

Question No 18: As for email and web browser protection which of the following browser and Email Client should be used in an Organization. You ca chose Multiple options?

A. Fully Supported
B. Latest version
C. Initial version
D. Only Microsoft Browser and email Client.
E. Open source

Q No 19: Topic No 231: COBIT (Control Objectives for Information and Related Technologies)
– ISACA (Information Systems Audit and Control Association) framework for IT Governance
– COBIT 5 helps enterprises to create optimal value from IT by maintaining a Balance between realizing benefits and optimizing risk levels and resource use (ISACA)
•• COBIT 5 brings together **five principles** that allow the enterprise to build an effective Governance and management framework (ISACA)
• Based on a holistic set of **seven enablers** that optimizes IT investment and use for the Benefit of stakeholders (ISACA)

Q No 20: What is Information Security governance?

– "Security governance is the set of responsibilities and practices exercised by the board and executive management with the goal of providing strategic direction, ensuring that objectives are achieved, ascertaining that risks are managed appropriately and verifying that the enterprise's resources are used responsibly

Q No 21: Why is security governance at stage 4?

– First build a building and then manage it

– First 2 stages build up the essential foundation

– 3 rd. stage implements advanced security measures

– Then (4th stage) it is time to manage

Q no 22: Software Assurance Maturity Model (SAMM) Governance Phase: (Repeated in exams)

• OWASP Software Assurance Maturity Model (SAMM) Governance Phase:

– Strategy & Metrics

– Education & Guidance

– Policy & Compliance

• **Strategy & Metrics:** – Focused on establishing the framework within an organization for a software security assurance program. –

• **Education & Guidance:** – Focused on arming personnel involved in the software lifecycle with knowledge and resources to design,

• **Policy & Compliance**: – Focused on understanding and meeting external legal and regulatory requirements while also driving internal security standards to ensure compliance in a way that's aligned with the business purpose of the org.

Q No 23: Info security Governance initial Block.

Initial

- Policy
- Responsibility
- Recourse and priority
- Periodic review

Intermediate

- Change management
- SOP,s
- Awareness
- Monitoring

Mature

- Risk management
- Internal audit
- Incident management

Info sec Governance Block arrange them. (Aise table ho ga usko arrange kerna ho ga. yad ker lo initail intermdiate and mature blocks k Name) sari yad ker lain intial inter and maure

Awareness	Intermediate
Monitoring	Intermediate
Policy	Initial
Periodic review	Initial
Internal Audit	Mature
Responsibility	Initial

Q No: 24: Info security governance initial block detail. (most repeating)

ACTIVITY	RESPONSIBLE	DETAIL
POLICY	DEVELOPED BY CISO SIGNED OFF BY BOARD/EXECUTIVE	SETS THE SCOPE, OBJECTIVES, FRAMEWORK, REQUIREMENTS
RESPONSIBILITY & AUTHORITY	BOARD/EXECUTIVE	ASSIGNS ROLES, RESPONSIBILITIES, AND AUTHORITY FOR INFOSEC PROGRAM
RESOURCE ASSIGNMENT & PRIORITY SETTING	BOARD/EXECUTIVE	ALLOCATION OF RESOURCES AND BUDGET FOR THE INFOSEC FUNCTIONS
PERIODIC REVIEW	BOARD/EXECUTIVE	MONITOR AND REVIEW THAT THE GOALS OF THE INFOSEC PROGRAM ARE BEING MET

Question No 25: The table given below TIER was given to you have to write responsibility Or Responsibility was given write TIER

Whose Responsibility Is InfoSec Governance ?

TYPICAL ORGANIZATIONAL TIERS AND MEMBERS

TIER	MEMBERS
BOARD (STEERING COMMITTEE)	BOARD MEMBER, CIO, CISO, IT MANAGEMENT, (SOME KEY BUSINESS MEMBERS)
IT MANAGEMENT (CIO)	GMs BELONGING TO IT MANAGEMENT, CISO
CISO/SECURITY HEAD	CISO AND ISMC
IT & SECURITY TEAMS	IT TEAMS AND PROJECT TEAMS

Q no 26: What is a patch?

– "A patch is a piece of software designed to update a computer program or its supporting data, to fix or improve it. This includes fixing security vulnerabilities and other bugs"

What are general steps for patch management? (yeh steps mostly ate hain exams main)

Step1: Establish baseline IT assets inventory

Step 2: Gather software patch and vulnerability information

Step3: identify vulnerability relevancy and filter to assign to end point

Step 4: review approve and mitigate patch management

Q No 27: What is patch management?●

– Patch management is an area of systems management that involves acquiring, testing, and installing multiple patches (code changes) to an administered computer system.

Patch management tasks :● – Maintaining current knowledge of available patches, deciding what patches are appropriate for particular systems, ensuring that patches are installed properly, testing systems after installation, and documenting all associated procedures, such as specific configs required.

Risk of not patching:● – By not applying a patch you might be leaving the door open for a malware attack

Q No: 28: Topic No 283: Key Leadership Qualities Of InfoSec (Head IMP Repeating)

• Lets examine the key leadership qualities of the Information Security Head or the key resource driving the Security Transformation Program

• Authenticity

• Candidness

• Fairness & fair play

• Team environment

• Recognizing talent and hard work

• Celebrating success!

• Authenticity –

IT is complex – No one person "knows-it-all" – Communicate that each individual has limitations – Admit mistakes and failures – Give credit where it is due

• Candidness: – Call a spade a spade – Honesty and straight-talk – Hear feedback and give respect to views of everyone

• Fairness & Fair Play: – Promote performance and merit – Adjust players in the right positions based on their strengths – Coach and guide team to perform and achieve results

• Team Environment: Discourage solo-flight and promote team consensus, team reviews, and team achievements – Single out and coach individuals playing turf tactics

• Recognize Talent & Hard Work: – Identify self-promotion versus talent combined with hard work – Encourage hard workers who are team players

Q no 29: Roles & responsibilities in security governance.

• Roles & responsibilities:

– Is right person working at the right place?

– Do key people tasked with security governance & documentation has the right skills and experience to build documentation?

– Are staffs aware of their responsibilities related to security governance documentation … policies, SOPs, checklists, etc?

– Is documentation and process approach part of staff JDs & appraisal?

Q No 30: Four-layer security transformation model or Four pillars of security transformation model

• Four-layer security transformation model provides the correct sequence and focus in order to address organizational security gaps

1. Security Hardening; Security controls on IT assets & process

2. Vulnerability Management; patching

3. Security Engineering; More complex security design & solutions

4. Security Governance; Managing the information security program

Q No 31: Topic No 198: How To Build Effective Info Sec Governance? (Imp Repeated)

• Key success factors: (***see also minor detail of all these 06 points***)

– Leadership

– Strategy

– Structure

– Reporting

– Project management

– Culture

• **Leadership**: – Executive management role – Tone at the top Drive pressing priority – Approves budgets and resources – Periodic review of progress

• **Strategy**: – How the objectives will be practically achieved while achieving the technical, governance, and performance goals – How the organization will gear up and focus for the security transformation

• **Structure:** –– What hierarchies, team structures, reporting lines, and resources will come together – How will different teams work together to achieve the common goals?

• **Reporting**: – What will be reported? – What will be the frequency of reports? – Who will perform review and assurance? – Who will monitor and track progress?

• **Project Management**: – How will an exceptional execution discipline be built? – How will milestones and performance be tracked? – How will project management best-practices be utilized?

• **Culture:** – How will an open, cooperative, authentic, and committed culture be built? – How will contention and conflict be eliminated? – How will a performance driven culture be promoted?



Q NO 32: Pen test and Red team Exercise (look a minor review on these steps)

: Establish a Penetration Testing Program

• Establish a program for penetration tests that includes a full scope of blended attacks, such as wireless, client-based, and web application attacks.

20.2: Conduct Regular External and Internal Penetration Tests

• Conduct regular external and internal penetration tests to identify vulnerabilities and attack vectors that can be used to exploit enterprise systems successfully.

20.3: Perform Periodic Red Team Exercises

• Perform periodic Red Team exercises to test organizational readiness to identify and stop attacks or to respond quickly and effectively.

. **20.7: Ensure Results from Penetration Test are Documented Using Open, Machine readable Standards**

• Wherever possible, ensure that Red Teams results are documented using open, machine readable standards (e.g., SCAP). Devise a scoring method for determining the results of Red Team exercises so that results can be compared over time.

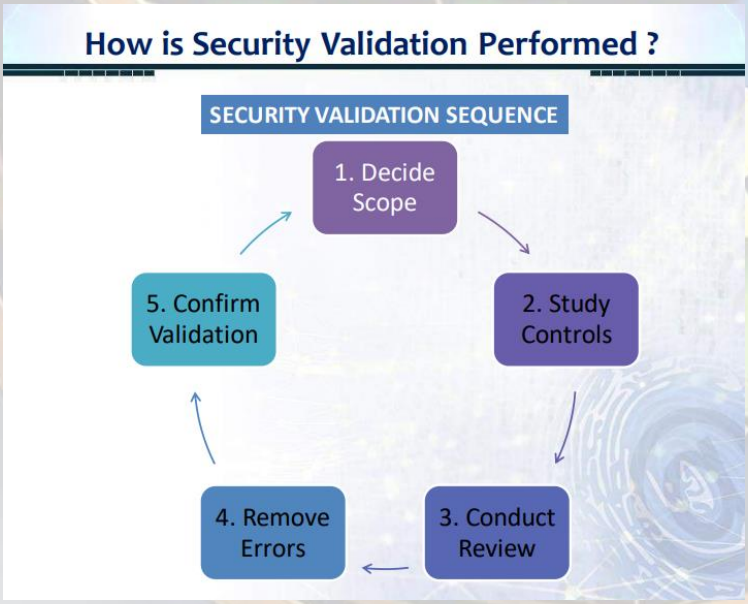
Q NO 33: Monitor and Detect Any Unauthorized Use of Encryption

• Monitor all traffic that is encrypted with protocols such as SSL or TLS leaving the organization and detect any unauthorized use of encryption.

Q No 34: Topic No 262: What is Security Validation?

• What does security validation mean?

– To confirm via walk-through of system or device that the security controls implemented by an IT team have actually been implemented correctly



Q No 35: Who implements the security controls?

– Under the Security Transformation Model, security controls are implemented by the IT teams

Q No 36: Who conducts security validation?

– Security controls are validated by the Information Security team or by a third party consultant following the principle of segregation of duty

Q No 37: Why do we need to validate security controls?

– To check the completeness of the controls

– To check the correctness of the controls

– As an overall assurance

Q No 38: Topic No 268: Software Security Testing & Validation–1 (imp)

• The OWASP Software Assurance Maturity Model (SAMM) undertakes software security testing & validation during the following phases:

– Verification

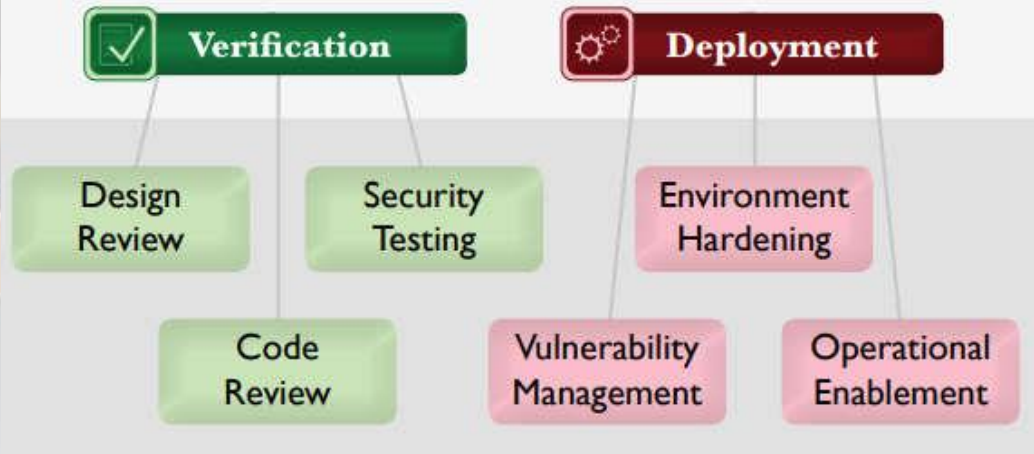
– Deployment

• OWASP Software Assurance Maturity Model (SAMM) Verification Phase:

– Design Review

– Code Review

– Security Testing



-
-
- **OWASP Software Assurance Maturity Model (SAMM) Deployment Phase**
    A. Environment Hardening
    B. Vulnerability Management
    C. Operational Enablement

Q No 39: Topic No 270: Embedding Info Sec In to Project Management (IMP)

• PMIs five phases of project management:
– Initiate
– Plan
– Executing
– Controlling
– Closing (Also see these steps minor look for detail).

Q No 40: topic 235 RISK MANAGEMENT – FRAMEWORK

– RISK MANAGEMENT FRAMEWORK

1: Risk Management architecture,

2: Risk management Strategy

3: Risk Management Protocols

• This is often referred to as the **risk architecture, strategy and protocols of the organization**,



Table 2: Risk management framework

Risk management architecture
• Committee structure and terms of reference
• Roles and responsibilities
• Internal reporting requirements
• External reporting controls
• Risk management assurance arrangements
Risk management strategy
• Risk management philosophy
• Arrangements for embedding risk management
• Risk appetite and attitude to risk
• Benchmark tests for significance
• Specific risk statements/policies
• Risk assessment techniques
• Risk priorities for the present year
Risk management protocols
• Tools and techniques
• Risk classification system
• Risk assessment procedures
• Risk control rules and procedures
• Responding to incidents, issues and events
• Documentation and record keeping
• Training and communications
• Audit procedures and protocols
• Reporting/disclosures/certification

Q No 41: Topic No 237: ISO31000:2018 – RISK MANAGEMENT – HOW TO IMPLEMENT

(1) Plan;

(2) Implement;

(3) Measure; and

(4) Learn.

Risk management Frame work 05 component:

1. Integration,
2. 2 designs,
3. 3 Implementation,
4. 4. Evaluation ,
5. 5 Improvement

Q No 42: **What is an internal security assessment?**
(Q yeh aye ga what is internal assessment, mention any one reason definition k bad neche se koi se kuch steps bata dena)

DEFINATION: An effort to assess the security posture, risks, or vulnerabilities for any project, service, application, or device

Q No 43: Topic No 272: Different Types Of Security Assessments

- Vulnerability assessment
- Penetration test
- Audits
- White box/grey box/ black box assessments
- Risk assessment
- Threat assessment
- Bug bounty
- Red team

Sequence of security assessment:

1. Management approval or communication
2. Assign resources
3. Build plan, scope and objectives
4. Conduct assessment
5. Report findings & remediation measures

Q No 44: **When is an internal security assessment required**?

– Launch of a new IT project or service

– When an incident has occurred

– On change of leadership

– Regulatory or compliance requirements.

Q No 45: **What is the purpose of effective toll scanning**? (an search from google)

To perform external and internal reconnaissance of available infrastructure component, network scanning tool can be used. A network scanning tool aims to identify active hosts on a network, either to attack them, or to assess vulnerability in the network.

Q No 46: What are five steps in business continuity plan management. (please verify this)

Five phases of development and maintaining business continuity plan

Phase1: Access your risk (natural disaster, cyber-attack, ransom ware, data corruption,)

Phase 2: Business impact analysis

Phase 3: Identify critical assets

Phase 4: Back up your data

Phase 5: Plan for recovery. 6. Test your plan

Q No 47: Topic no 142: IT Asset Management Challenges (Mention the name of valid section healing in the appendix isms Types stored in assests inventory just names) Ans (Asset management)

• The typical enterprise has hundreds or thousands of IT assets with a fast-paced business environment
• Tough challenge to keep all IT assets tracked and updated with all the right software patches and updates

• **Challenges:**

– Asset discovery & tracking
– Antivirus status
– Windows & OS updates
– Patch management
– Change management

Q no 48: Pakistan's InfoSec paradigm

– Governance overkill
– Reactive
– Superficial

– Complete absence of underlying security controls

Q No 49: Topic No 202: Role Of CISO In Driving Info sec Program



Q No 50: Topic No 203: Key Inhibitors For Security Program Failure



Q No 51: Topic No 207: Security Documentation: Standards

Policies:
Policies are **formal statements produced and supported by senior management**. They can be organization-wide, issue-specific or system specific. Your organization's policies should reflect your objectives for your information security program.
Standards
Standards are **mandatory actions or rules** that give formal policies support

And direction. One of the more difficult parts of writing standards for an Information security program is getting a company-wide consensus on what Standards need to be in place.

Procedures
Procedures are detailed step by step instructions to achieve a given goal or mandate. They are typically intended for internal departments and should adhere to strict change control processes.

Guidelines
Guidelines are recommendations to users when specific standards do not apply. Guidelines are designed to streamline certain processes according to what the best practices are. Guidelines, by nature, should be open to interpretation and do not need to be followed to the letter.

Q No 52: Topic No 211: ISMS: Leading Info Sec Governance Framework

Specifies the requirements for establishing, implementing, maintaining and continually improving an information security management system

Reference		Description
Mandatory	Clause 4	Context of the organization
	Clause 5	Leadership
	Clause 6	Planning
	Clause 7	Support
	Clause 8	Operation
	Clause 9	Performance evaluation
	Clause 10	Improvement

Reference		Description	Control Total
Discretionary	A5	Information security policies	2
	A6	Organization of information security	7
	A7	Human resource security	6
	A8	Asset management	10
	A9	Access control	13
	A10	Cryptography	2
	A11	Physical and environmental security	15
	A12	Operations security	14
	A13	Communications security	7
	A14	System acquisition, development and maintenance	13
	A15	Supplier relationships	5
	A16	Information security incident management	7
	A17	Information security aspects of business continuity management	4
	A18	Compliance	8

Q No 53: What is ISO27002:2013?

– Information technology -- Security techniques -- Code of practice for information security controls

– Renamed from ISO 17799

• **PCI Data Security Standard (DSS):**

– Designed to ensure that ALL companies that accept, process, store or transmit

– Managed by Security Standards Council (SSC)

– SSC is an independent body that was created by the major payment card brands (Visa, MasterCard, American Express, Discover and JCB

– 6 Broad goals and 12 requirements



Q No 54: Topic No 230: NIST FRAMEWORK

• The Computer Security Resource Center (CSRC) website guides users to NIST resources on **computer, cyber, and information security and privacy.**

• Its content includes **publications, projects, research, news and events** from the NIST Information Technology Laboratory's (ITL) two security divisions

Q No 55: Types of Changes:

Standard changes are changes to a service or to the IT infrastructure where the implementation process and the risks are known upfront.

Normal Changes

• **T**hose that must go through the change process before being approved and implemented. If they are determined to be high-risk, a change advisory board must decide whether they

will be implemented.

Emergency Changes

• Arise when an unexpected error or threat occurs, such as when a flaw in the infrastructure related to services needs to be addressed immediately.

Q No 56: **CYBER SECURITY CHALLENGES:**

– Reactive
– Superficial
– Contention
– Box-Approach
– Governance-Overkill

Q No 57: Topic No 254: CYBER SECURITY MATURITY MATRIX

Sr No	Layer
1	FOUNDATION
2	FUNDAMENTALS
3	Hardened
4	PROTECTED
5	MONITORED
6	. SECURED

I. FOUNDATION

Edge FW With Filtering
Active Directory (WS/S)
Licensed Enterprise AV (WS/S)
Licensed Windows OS (WS/S) Or Open Source

: RED TEAM PENETRATION TESTING

• Red team and blue team
• Attack & defense simulation
• Continuously find holes in security defenses
• Uncover security vulnerabilities before hackers exploit them

Q No 58: Types of security testing: (IMP)

– Vulnerability assessment (VA)
– Penetration testing (PT)
– Other security tests through various automated tools
– Code review (initiated in test environment)

Q No 59: What is security accreditation?

– Accreditation is the formal acceptance of the adequacy of the system's Overall security by the management (SANS)

As defined by **SANS (SysAdmin, Audit, Network, Security)**, accreditation is the responsibility of management to formally approve the system's security measures before it goes into production.



Topic No 267: Embedding Info Sec Lifecycle into SDLC (Yeh pora topic important hai)

Q No 60: Topic No 270: Embedding Info Sec In to Project Management

• PMIs five phases of project management:
– Initiate
– Plan
– Executing
– Controlling
– Closing

Q No 61: Topic No 278: Benefits Of the Security Transformation

• **Key Benefits**
– Prevention of attacks– Prevention of fraud & pilferage– A reliable & robust IT set
• **Impact of attacks**:
– Loss of market goodwill– Loss of customer confidence, Regulatory fines•
– An **Prevention of Fraud & Pilferage:**effective Information Security Program makes it harder to conduct fraud, abuse,
Or misuse without getting detected
– Controls in business process
– Audits
• **A Reliable & Robust IT Setup**: – Business continuity & DR– Redundancy– Backups– Capacity management – Change management

Q No 62: What are objective of applying Cryptography (See topic no 218)

A.10.1.2 KEY MANAGEMENT Control: A policy on the use, protection and lifetime of cryptographic keys shall be developed and implemented through their whole lifecycle.

Q No 63: Control as per ISO27001?

Which type should use assets inventory long

: Deploy an automated asset inventory discovery tool and use it to build a preliminary inventory of systems connected to an organization's public and private network.

Maintain an asset inventory of all systems connected to the network and the network devices themselves, recording at least the network addresses, machine name(s), purpose of each system, an asset owner responsible for each device…

Q No 64::Write the name perform activities in control validation process?

Ans: The activities involve in control validation are typically referred as a "Control testing" or "Security control assessment"

Q No 65: Which action a rise management support of security transformation

Ans: Topic No 281:
Actions To Raise Management Support
• What can you do if your organizational management is not supporting for the Information Security Transformation Program?
a) Understand the organizational business requirements and potential impact
b) Understand regulations & sector best-practices
c) Evaluate the security posture
d) Assess the extent of work and resources required
e) Present your report

Q No 66: Answer the following with respect to vulnerability.

Q; Which team have primary ownership

Ans: Information security team

Q: which team tests the patches in environment?

Ans: IT ops team

Q No 67: Significance of vulnerability management in transformation model? (Ans from chat gpt)

Vulnerability management is a critical component of a **transformation model** in any organization undergoing digital transformation, business process redesign, or IT modernization.

Q No. 68: Mention any two factors behind insecure software.

01, Connectivity,

02, Extensibility.

03. Complexity:

Q No 69: Write name of any five activities performed in accreditation process.

01. Organize, 02. . Prepare Checklist, 3. Confirm Tests, 4. Documentation & Processes (Complete) 5. Team Meeting, 6. Issue Accreditation

Q No 70: Which best practices are to be followed for applying security patches (ONLY steps names)

1. Use a change control process, 2. Read all related documentation, 3. Apply updates on a need-only basis 4. Testing 5. Plan to uninstall 6. Working backup and production downtime 7. Always have roll-back plan 8. Don't get more than 2 service packs behind

Q No 71: What are challenges associated with documented of security projects.

• Process culture absent:

Defective & voluminous documentation:

Training & awareness

• **IT Outsourcing examples:** –

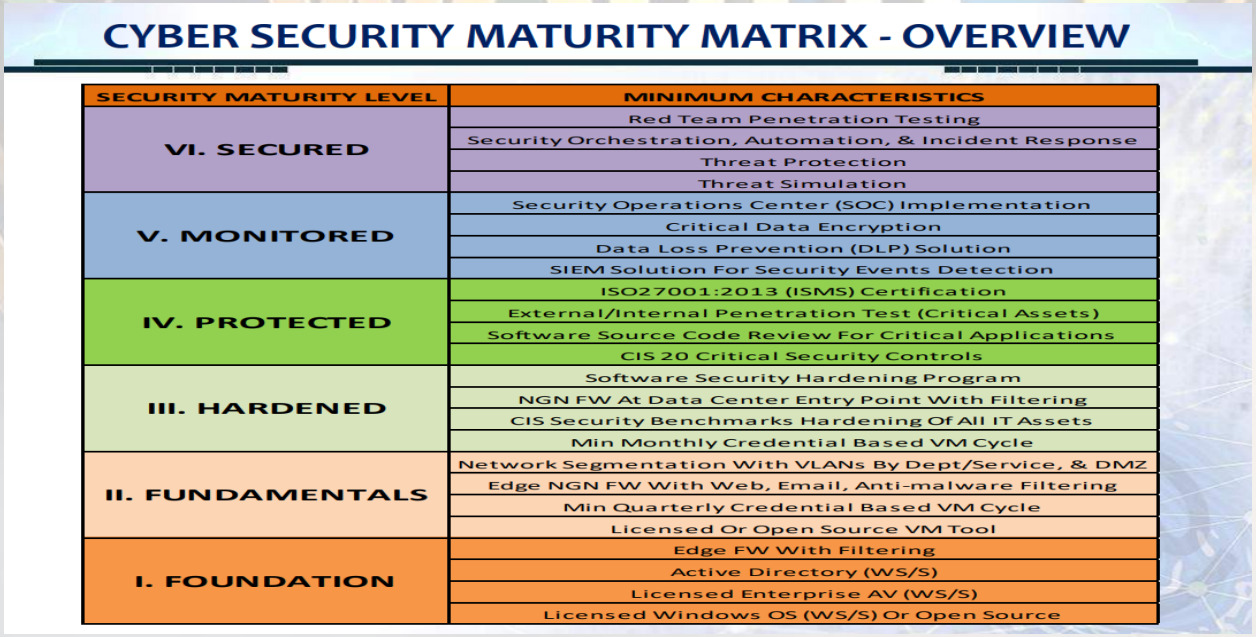
Call centers – Hosted servers – Software development – Workstation helpdesk functions – Network services – Any other arrangement

Q No 72: Which vulnerability scanner is used to look for both code based and configuration based vulnerability?

Answer: Use a SCAP validated vulnerability scanner that looks for both code-based vulnerabilities and configuration-based vulnerabilities.

Question No 73: Arrange the Cyber security maturity matrix (is main yeh oper neche hon ge inko arrange kerna ho ga. is se 2 se 3 question a sakte hain IMP)

Ans:



Question No 74: What type of IT assets do not have a CIS/DISA STIG?

Ans: – Software applications (ASP.NET, PHP, Other)

– Other applications such as asterisk deployments

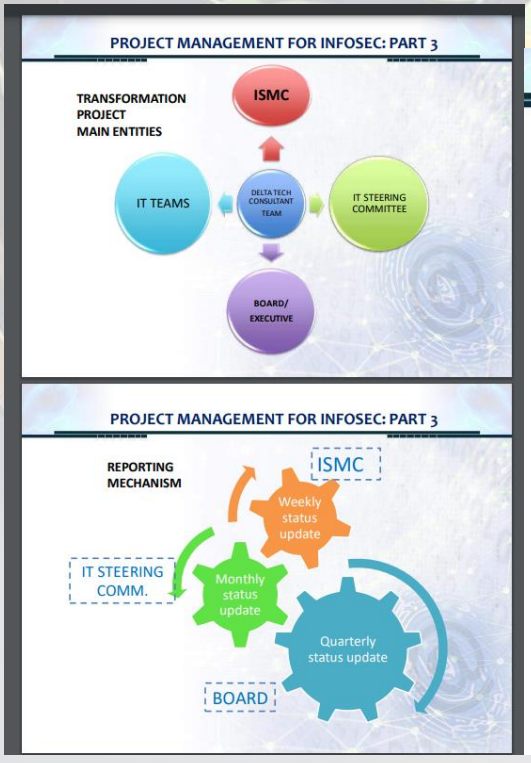
Question No 75: Following table contains some CHARACTERISTICS of exploit that causes security breaches you are required to identify the type of exploit as local or remote?

Required prior to the Vulnerability system	Local	----
Works over Network	------	Remote
Does not require any prior Access	-------	Remote
Exploit in the through internet	-------	Remote

Answer: Remote exploit: – A remote exploit works over a network and exploits the security vulnerability without any prior access to the vulnerable system.

• **Local exploit**: – A local exploit requires prior access to the vulnerable system and usually increases the privileges of the person running the exploit past those granted by the system administrator

Topic No 245: PROJECT MANAGEMENT FOR INFOSEC:



PROJECT MANAGEMENT FOR INFOSEC: PART 3

Forum	Frequency	Report Format	Objectives
ISMC	WEEKLY	PDF MINS OF MEETING	IDENTIFY TASKS, RESPONSIBILITY, TIMELINE
STEERING COMMITTEE	MONTHLY	PPT PRESENTATION	INFORM RELEVANT HEADS OF PROGRESS, IDENTIFY CHALLENGES
BOARD MEETING	QUARTERLY	PPT PRESENTATION	CRITICAL LOOK AT PROGRESS ACHIEVED, IDENTIFY CHALLENGES & SOLUTIONS, SEEK ASSISTANCE

Risk rating is assign to vu or the basis of two criteria. You require just point out crietwra?

(Search this on own basis from chat gpt

Question No 76: Mention the names of framework against which Nessus scanner gives Configuration Auditing features?

Answer: –

Configuration auditing:
CERT,
CIS, COBIT/ITIL,
DISA STIGs,
FDCC,
ISO,
NIST,

Question No 77: In the Qualys Guard scanning methodology once the TCP port scanning has been performed mention the detection test?

Answer: OS Detection

– Once the TCP port scanning has been performed, the scanner tries to identify the operating system running on the host.

– This detection is based on sending specific TCP packets to open and closed ports.

Question No 78: Stages of 3rd party penetration test??

Ans :

1. System port scanning
2. Identification of system services
3. Identification, verification
4. Penetration testing